Team ISEd Tea

Iowa State University

(Team 7)

White Team Documentation

Table of Contents

Table of Contents.... 1
Network Architecture....3
Public Services....4
Port Forwarding Rules.... 5
Servers....6
Active Directory....6
Description....6
Vulnerability Remediation....6
Security Configuration....7
Tickets Server.... 8
Description....8
Vulnerability Remediation....8
Security Configuration....8
Security and Usability Testing....9
Mgmt....11
Description....11
Vulnerability Remediation....11
Security Configuration....12
Security and Usability Testing....12
Admin.... 14
Description....15
Vulnerability Remediation....15
Security Configuration....15
Security and Usability Testing....15
WWW Server....18
Description....19
Vulnerability Remediation....19
Security Configuration....19
Security and Usability Testing....20
Network Firewall.... 22
Description....22
Security Configuration....22
SIEM....22
Description....23
Web Application Firewall....23
Description....23

Network Architecture

The network architecture we decided to create placed our services behind a network firewall allowing access to required services via NAT rules and port forwarding. The services listed in Table 1 detail the publicly available services and the firewall rules used for port forwarding are described in Table 2. Figure 1 below demonstrates a graphical representation of the network.

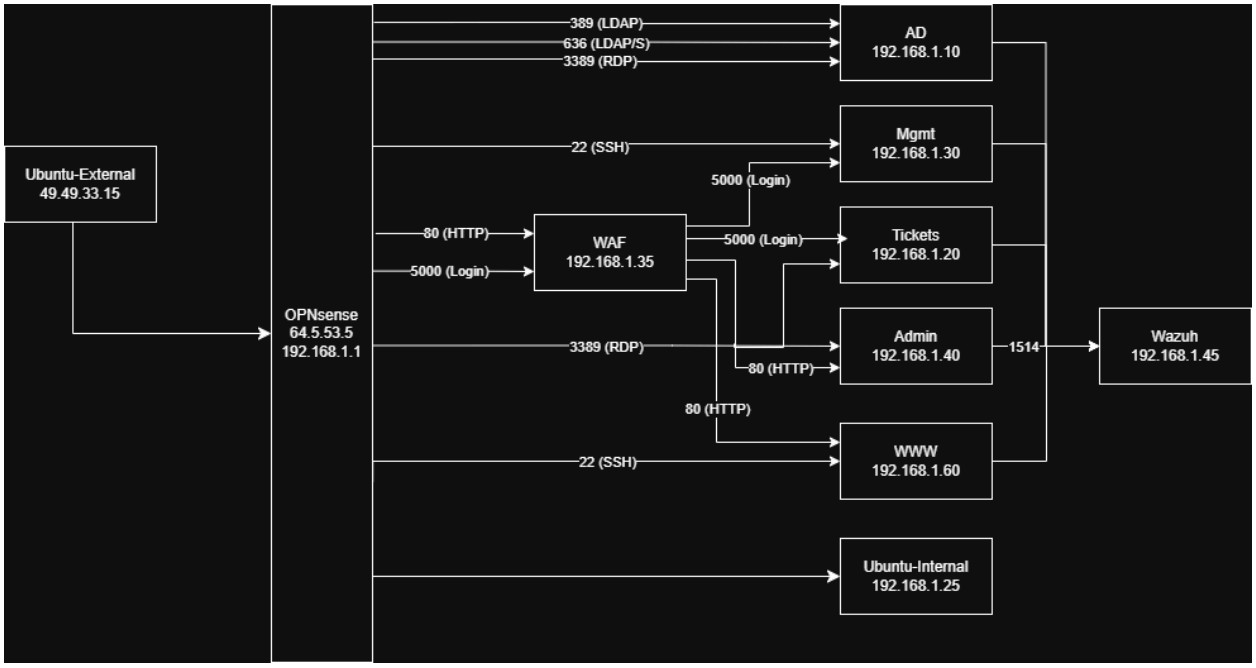


Figure 1: Network Diagram

Public Services

The following Services are publicly available:

Domain Name	IP	Port
ad.team7.isucdc.com	49.49.33.10	389 (LDAP), 3389 (RDP), 636 (LDAPS)
tickets.team7.isucdc.com	49.49.33.20	5000 (HTTP), 3389 (RDP)
mgmt.team7.isucdc.com	49.49.33.30	5000 (HTTP), 22 (SSH)
admin.team7.isucdc.com	49.49.33.40	80 (HTTP), 3389 (RDP)
www.team7.isucdc.com	49.49.33.50	80 (HTTP), 22 (SSH)

Table 1: Publicly available services

Port Forwarding Rules

On the network firewall, we implemented the following port forwarding rules to allow external users to access services hosted on machines behind the firewall. The NAT rules are as follows (as pictured in Table 2):

Domain Name	External IP	Port	Internal IP	Port
ad.team7.isucdc.com	49.49.33.10	389	192.168.1.10	389
ad.team7.isucdc.com	49.49.33.10	3389	192.168.1.10	3389
ad.team7.isucdc.com	49.49.33.10	636	192.168.1.10	636
tickets.team7.isucdc.com	49.49.33.20	5000	192.168.1.35	5000
tickets.team7.isucdc.com	49.49.33.20	3389	192.168.1.20	3389
mgmt.team7.isucdc.com	49.49.33.30	5000	192.168.1.35	5000
mgmt.team7.isucdc.com	49.49.33.30	22	192.168.1.30	22
admin.team7.isucdc.com	49.49.33.40	80	192.168.1.35	80
admin.team7.isucdc.com	49.49.33.40	3389	192.168.1.40	3389
www.team7.isucdc.com	49.49.33.50	80	192.168.1.35	80
www.team7.isucdc.com	49.49.33.50	22	192.168.1.50	22

Table 2: Port forwarding rules

Servers

Active Directory

Domain name: ad.team7.isucdc.com

Public IP address: 49.49.33.10

Private IP address: 192.168.1.10

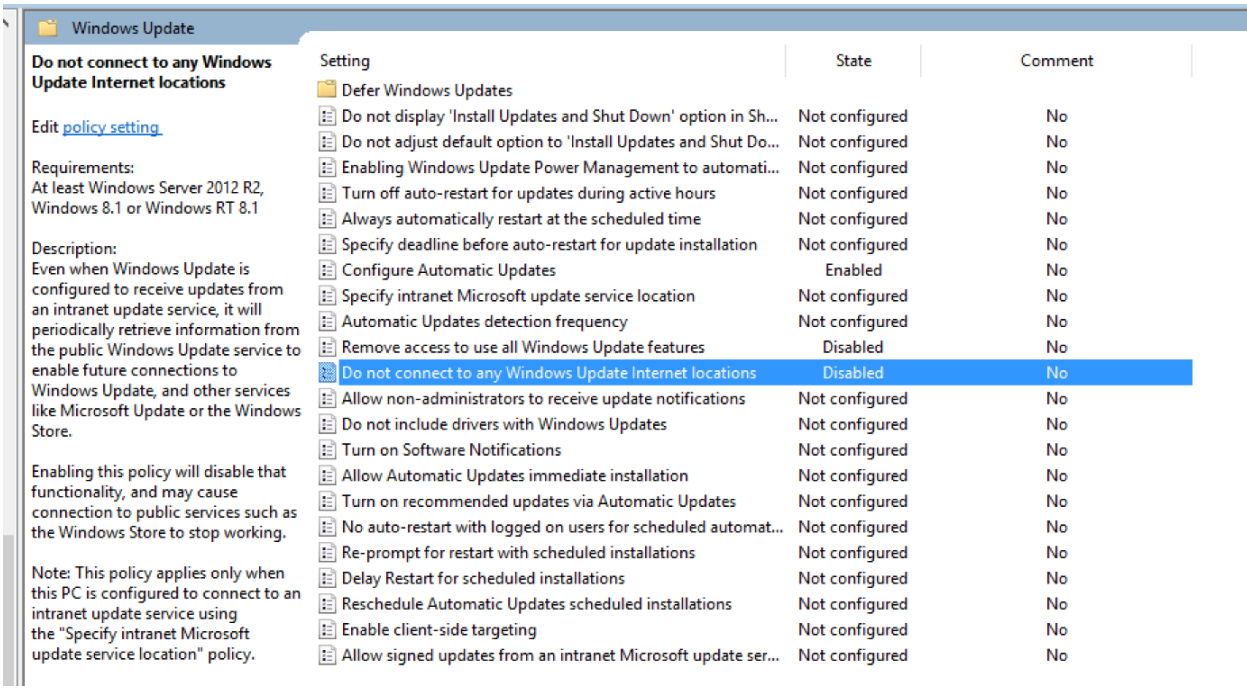
Operating system: Microsoft Windows Server 2016 (1607)

Description

The Active Directory server runs the domain controller for our *team7.isucdc.com* domain and provides centralized authentication for the competition servers (AD, Tickets, Mgmt, Admin, and WWW). To support this authentication across all competition machines, each server was joined to the domain by using either built-in Windows functionality or *realmd* for the Linux servers. This machine also hosts the Certificate Authority used by the Ticketing machine.

Vulnerability Remediation

- Edited the GPedit.msc to include windows updates and updated the group policy using these commands:
    - Set-Service -Name BITS -StartupType Automatic
    - Set-Service -Name wuauserv -StartupType Automatic
    - Start-Service BITS, wuauserv
    - Restart-Service BITS, wuauserv

- 

-
- Edited the DNS table to delete a wrong entry “WIN-87…” and added the admin box to fix DNS
- Downloaded Firefox to use AD security testing tools
- Used Ping Castle to learn about the vulnerabilities in the AD
- Used this command to disable SMBv1 which is an Eternal Blue attack: Set-SmbServerConfiguration -EnableSMB1Protocol $false -Force
- Following the disablement of the SMB1 protocol I removed it entirely: Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol -Remove
- Use this command to update any changes made: gpupdate /force
- Ran these two commands to prevent an ADCS Certificate takeover, which would allow a user to request a new certificate and imitate and Admin:
    - Stop-Service -Name "CertSvc" -Force
    - Set-Service -Name "CertSvc" -StartupType Disabled
- Disabled the Spooling print service that can be attacked on the DC:
    - Stop-Service -Name "Spooler" -Force
    - Set-Service -Name "Spooler" -StartupType Disabled
- Ran this command to protect OUs from accidental deletion where some OUs might be unprotected:
    - Get-ADOrganizationalUnit -Filter * | Set-ADOrganizationalUnit -ProtectedFromAccidentalDeletion $true

- Massive privilege nesting issue with a guy “Edward Matthews from the Transit department in the IT admin group:

```
Administrator: Windows PowerShell
PS C:\Users\Administrator> Get-ADGroupMember -Identity "Domain Admins" | Select-Object Name, SamAccountName

Name           SamAccountName
----           --------------
Administrator  Administrator
Domain Users   Domain Users
Transit Admins Transit Admins


PS C:\Users\Administrator> Get-ADGroupMember -Identity "Enterprise Admins" | Select-Object Name, SamAccountName

Name          SamAccountName
----          --------------
Administrator Administrator


PS C:\Users\Administrator> Get-ADGroupMember -Identity "Administrators" -Recursive | Select-Object Name, SamAccountName

Name            SamAccountName
----            --------------
Administrator   Administrator
joy.newman      joy.newman
edward.matthews edward.matthews
```

  - Ran these commands to remove Transit Admins from the domain group: Remove-ADGroupMember -Identity "Domain Admins" -Members "Domain Users" -Confirm:$false Remove-ADGroupMember -Identity "Domain Admins" -Members "Transit Admins" -Confirm:$false
  - And remove the Transit Admins from the local group: Remove-ADGroupMember -Identity "Administrators" -Members "joy.newman", "edward.matthews" -Confirm:$false
  - Added the admins back for the IT group: Add-ADGroupMember -Identity "Domain Admins" -Members "melissa.robles", "roger.cox"
- Ran this command and did not find any backdoor users: Get-ADUser -Filter * -Properties WhenCreated | Select-Object Name, WhenCreated | Sort-Object WhenCreated -Descending
- Validated we did not have the “nuclear nesting” misconfiguration that happened earlier with the IT admins
- Disabled the Local AD Guest account using command: Disable-LocalUser -Name "Guest"
- Removed the NetBios credential sniffing attack vulnerability. Attackers can steal password hashes if multicast name resolution is not turned off: $adapters = Get-WmiObject Win32_NetworkAdapterConfiguration | Where-Object {$_.IPEnabled -eq $true} foreach ($adapter in $adapters) { $adapter.SetTcpipNetbios(2) }
- Disabled Web Server (IIS) that could open web shells for red team access:
  - Stop-Service W3SVC
  - Set-Service W3SVC -StartupType Disabled
  - Stop-Service W3SVC, WAS, IISADMIN -Force
  - Set-Service W3SVC, WAS, IISADMIN -StartupType Disabled
- Double verified the Remote Registry updating is diabled: Set-Service RemoteRegistry -StartupType Disabled
- Get-ScheduledTask -TaskName "QueueReporting" | Select-Object -ExpandProperty Actions

- Attempted to prevent “Pass-The-Hash” attack by adding the IT admins to a protected users group. This should in theory force Kerberos and stop passing of plaintext and NTLM hashes
    - Add-ADGroupMember -Identity "Protected Users" -Members "melissa.robles", "roger.cox"
- Disabled NTLM and LM login authentication protocols. Should prevent any downgrading to legacy protocols
    - $path = "HKLM:\System\CurrentControlSet\Control\Lsa\MSV1_0"
    - Set-ItemProperty -Path $path -Name "RestrictSendingNTLMTraffic" -Value 2
    - Set-ItemProperty -Path $path -Name "RestrictReceivingNTLMTraffic" -Value 2
    - Set-ItemProperty -Path "HKLM:\System\CurrentControlSet\Control\Lsa" -Name "LmCompatibilityLevel" -Value 5
- Disable Debug Programs so they cannot find the passwords in the memory dump as easily. Should make Mimikatz Tool a pain to use:
    - secedit /export /cfg C:\secpol.cfg
    - $config = Get-Content C:\secpol.cfg
    - $newConfig = $config -replace 'SeDebugPrivilege = *S-1-5-32-544', 'SeDebugPrivilege = '
    - $newConfig | Out-File C:\secpol.cfg -Encoding ascii
    - secedit /configure /db $env:windir\security\local.sdb /cfg C:\secpol.cfg /areas USER_RIGHTS
    - Remove-Item C:\secpol.cfg
- Ran the snaffler AD vulnerability tool and found no major vulnerabilities
- Ran Winpeas and got a log of all the broken items and vulnerabilities on the machine after fixing many ofthe issues previous;y listed
- Ran a custom script (images below) that checked for broken service permissions that had Administrator access (bad) and then fixed them to the default perms:

- Select Administrator: Windows PowerShell

```
    Directory: C:\Users\Administrator\Desktop


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
d-----        2/17/2026   4:52 PM                Ping Castle Initial Result
-a----        2/20/2026   2:37 PM            949 perms.ps1.txt
-a----        2/20/2026   2:38 PM            949 perm_check.ps1


PS C:\Users\Administrator\Desktop> ./perm_check.ps1
[!] Found Vulnerable Service: diagnosticshub.standardcollector.service
[+] Applied standard SDDL to diagnosticshub.standardcollector.service
[!] Found Vulnerable Service: DNS
[+] Applied standard SDDL to DNS
[!] Found Vulnerable Service: DFSR
[+] Applied standard SDDL to DFSR
PS C:\Users\Administrator\Desktop>
```

- perms.ps1 - Notepad

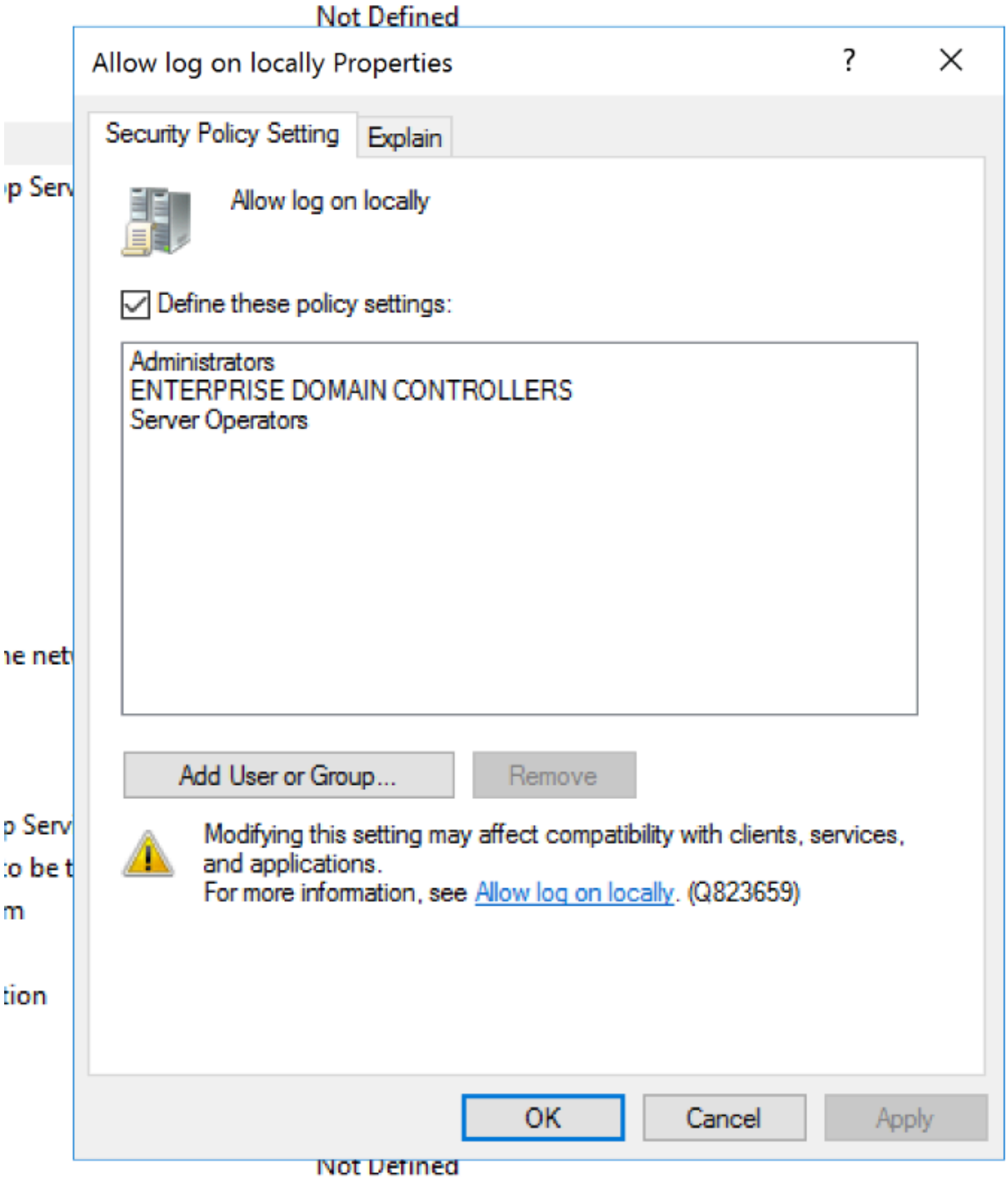
```
# 1. Define the services WinPEAS flagged in your log
$vulnerableServices = @("diagnosticshub.standardcollector.service", "DNS", "DFSR")

foreach ($svcName in $vulnerableServices) {
    # Check if service exists
    if (Get-Service $svcName -ErrorAction SilentlyContinue) {
        Write-Host "[!] Found Vulnerable Service: $svcName" -ForegroundColor Red

        # 2. Lockdown: Remove FullControl for Administrators and set to Read/Execute
        # This uses 'sc.exe' to set the Security Descriptor (SDDL)
        # WARNING: Use cautiously; standard SDDL for SYSTEM/TrustedInstaller only is safer
        # Below is a basic example to reset to a more standard 'Read-Only' for Admins
        # sc.exe sdset $svcName D:(A;;CCLCSWRPWPDTLOCRRC;;;SY)(A;;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;BA)(A;;CCLCSWLOCRRC;;;IU)(A;;CCLCSWLOCRRC;;;SU)

        Write-Host "[+] Applied standard SDDL to $svcName" -ForegroundColor Green
    }
}
```

- fix_service_perms - Notepad

```
# Define the root services registry path
$registryPath = "HKLM:\SYSTEM\CurrentControlSet\Services"

# Get all subkeys (individual services)
$subKeys = Get-ChildItem -Path $registryPath

foreach ($key in $subKeys) {
    try {
        # This command enables inheritance and removes explicit permissions
        # effectively resetting the service key to follow the parent 'Services' folder rules.
        $acl = Get-Acl $key.PSPath
        if ($acl.AreAccessRulesProtected) {
            Write-Host "[!] Fixing inheritance for: $($key.Name)" -ForegroundColor Yellow
            $acl.SetAccessRuleProtection($false, $true) # $false = enable inheritance
            Set-Acl -Path $key.PSPath -AclObject $acl
        }
    } catch {
        Write-Host "[X] Failed to modify $($key.Name). You may need to take ownership first." -ForegroundColor Red
    }
}
```

```
PS C:\Users\Administrator\Desktop> .\fix_service_perms.ps1
[!] Fixing inheritance for: HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\DcomLaunch
Set-Acl : Requested registry access is not allowed.
At C:\Users\Administrator\Desktop\fix_service_perms.ps1:15 char:13
+             Set-Acl -Path $key.PSPath -AclObject $acl
+             ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : PermissionDenied: (HKEY_LOCAL_MACH...ices\DcomLaunch:String) [Set-Acl], SecurityExceptio
   n
    + FullyQualifiedErrorId : System.Security.SecurityException,Microsoft.PowerShell.Commands.SetAclCommand

[!] Fixing inheritance for: HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Dhcp
[!] Fixing inheritance for: HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\DPS
Set-Acl : Requested registry access is not allowed.
At C:\Users\Administrator\Desktop\fix_service_perms.ps1:15 char:13
+             Set-Acl -Path $key.PSPath -AclObject $acl
+             ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : PermissionDenied: (HKEY_LOCAL_MACH...et\Services\DPS:String) [Set-Acl], SecurityExceptio
   n
    + FullyQualifiedErrorId : System.Security.SecurityException,Microsoft.PowerShell.Commands.SetAclCommand

[!] Fixing inheritance for: HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\EventLog
[!] Fixing inheritance for: HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\gpsvc
Set-Acl : Requested registry access is not allowed.
At C:\Users\Administrator\Desktop\fix_service_perms.ps1:15 char:13
+             Set-Acl -Path $key.PSPath -AclObject $acl
+             ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : PermissionDenied: (HKEY_LOCAL_MACH...\Services\gpsvc:String) [Set-Acl], SecurityExceptio
   n
    + FullyQualifiedErrorId : System.Security.SecurityException,Microsoft.PowerShell.Commands.SetAclCommand
```

  - Not all the the final script services ran because over 100 of them are not managed by Admin (TrustedInstaller owns them) but it is probably good enough
- Deleted everything from the recycle bin: Clear-RecycleBin -Force -ErrorAction SilentlyContinue
- Removed a ton of users so they cannot login and memory dump on AD. Here are the final authorized users:



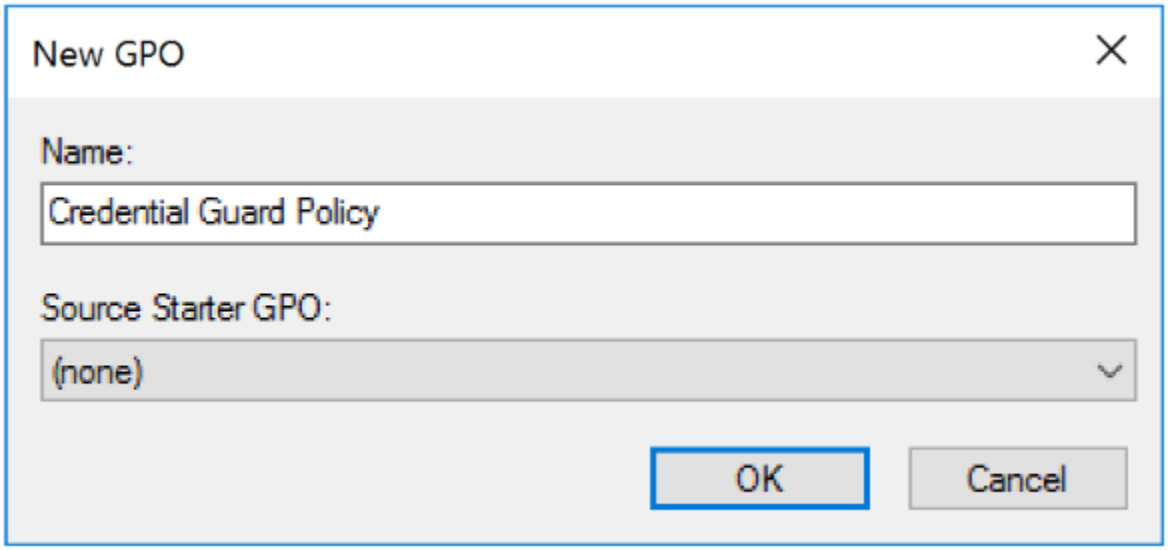
- I also, just like above, I removed non-admins, backup operators, etc. from the following User Rights Assignment:
    - Back up files and directories
    - Restore files and directories
    - Take ownership of files or other objects -> Removed Print operators
    - Shut down the system -> all except admins
    - Bypass traverse checking -> Removed Pre-Windows 200 Compatible Access

- Ran the powershell script below to double check that perms were for Admins only:
    - # Identify the group
    - $Group = "Group Policy Creator Owners"
    -
    - # Get all members
    - $Members = Get-ADGroupMember -Identity $Group
    -
    - # Remove everyone except the specific Administrator account
    - foreach ($Member in $Members) {
    - if ($Member.SamAccountName -ne "Administrator") {
    - Remove-ADGroupMember -Identity $Group -Members $Member -Confirm:$false
    - Write-Host "Removed $($Member.SamAccountName) from $Group" -ForegroundColor Green
    - }
    - }
- Did a remediation of AdminSDHolder:
    - # 1. Setup Variables
    - $DN = "CN=AdminSDHolder,CN=System,DC=team7,DC=isucdc,DC=com"
    - $IdentityToRemove = "BadActor" # <--- CHANGE THIS to the user/group identified in WinPEAS
    -
    - # 2. Use the full Provider Path to be safe
    - $ADPath = "AD:\$DN"
    -
    - try {
    - # Get the current ACL
    - $ACL = Get-Acl -Path $ADPath
    -
    - # Filter for the dangerous rules
    - $RulesToRemove = $ACL.Access | Where-Object {
    - $_.IdentityReference -like "*$IdentityToRemove*" -and
    - ($_.ActiveDirectoryRights -match "GenericAll" -or $_.ActiveDirectoryRights -match "WriteDacl")
    - }
    -
    - if ($RulesToRemove) {
    - foreach ($Rule in $RulesToRemove) {
    - Write-Host "Removing $($Rule.ActiveDirectoryRights) for $($Rule.IdentityReference)..." -ForegroundColor Cyan
    - $ACL.RemoveAccessRule($Rule)
    - }
    - # Apply the changes
    - Set-Acl -Path $ADPath -AclObject $ACL

```
        Write-Host "Successfully updated permissions on AdminSDHolder." -ForegroundColor Green
    } else {
        Write-Host "No matching risky permissions found for $IdentityToRemove." -ForegroundColor Yellow
    }
} catch {
    Write-Error "Failed to update ACL. Error: $_"
}
```

- More AD drive rule tightening:

```
$DN = "CN=AdminSDHolder,CN=System,DC=team7,DC=isucdc,DC=com"
$Target = "BadActor" # <--- CHANGE THIS

$Object = [ADSI]"LDAP://$DN"
$Sec = $Object.ObjectSecurity

$Rules = $Sec.GetAccessRules($true, $true, [System.Security.Principal.NTAccount])
foreach ($Rule in $Rules) {
    if ($Rule.IdentityReference -like "*$Target*" -and ($Rule.ActiveDirectoryRights -match "GenericAll|WriteDacl")) {
        $Sec.RemoveAccessRule($Rule)
        Write-Host "Removed permission for $Target"
    }
}

$Object.CommitChanges()
```



- Here is the script that each machine runs:

```
<#
.Synopsis
    Enables Virtualization-Based Security and Credential Guard.
    Deploy this via GPO Startup Script for domain-wide enforcement.
#>

# 1. Enable Virtualization-Based Security (VBS)
$vbsPath = "HKLM:\SYSTEM\CurrentControlSet\Control\DeviceGuard"
if (!(Test-Path $vbsPath)) { New-Item -Path $vbsPath -Force | Out-Null }

# Enable VBS
Set-ItemProperty -Path $vbsPath -Name "EnableVirtualizationBasedSecurity"
-Value 1 -Type DWord
# Require Secure Boot (1) or Secure Boot and DMA Protection (3)
Set-ItemProperty -Path $vbsPath -Name "RequirePlatformSecurityFeatures"
-Value 3 -Type DWord

# 2. Enable Credential Guard
$lsaPath = "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa"
# Value 1 = Enabled with UEFI Lock (Cannot be disabled via registry alone)
# Value 2 = Enabled without UEFI Lock (Remote management possible)
Set-ItemProperty -Path $lsaPath -Name "LsaCfgFlags" -Value 1 -Type DWord

# 3. Enable Hypervisor-Enforced Code Integrity (HVCI) - Recommended
hardening
$codeIntegrityPath =
"HKLM:\SYSTEM\CurrentControlSet\Control\DeviceGuard\Scenarios\Hypervisor
EnforcedCodeIntegrity"
if (!(Test-Path $codeIntegrityPath)) { New-Item -Path $codeIntegrityPath -Force |
Out-Null }
Set-ItemProperty -Path $codeIntegrityPath -Name "Enabled" -Value 1 -Type
DWord

Write-Host "Credential Guard registry keys applied. A reboot is required to
initialize VBS." -ForegroundColor Green
```

- Added to group policy “Always install with elevated privileges” set to Disabled so .msi files cannot be executed or installed by users
- Added to Group Policy: “Allow users to patch elevated products” set to Disabled
- Cleared the logs: Get-EventLog -List | ForEach-Object { Clear-EventLog -LogName $_.Log }
- Removed Console History: Remove-Item (Get-PSReadlineOption).HistorySavePath -ErrorAction SilentlyContinue

Security Configuration

- Installed IPBan, running as a scheduled task, and set a 15min lockout

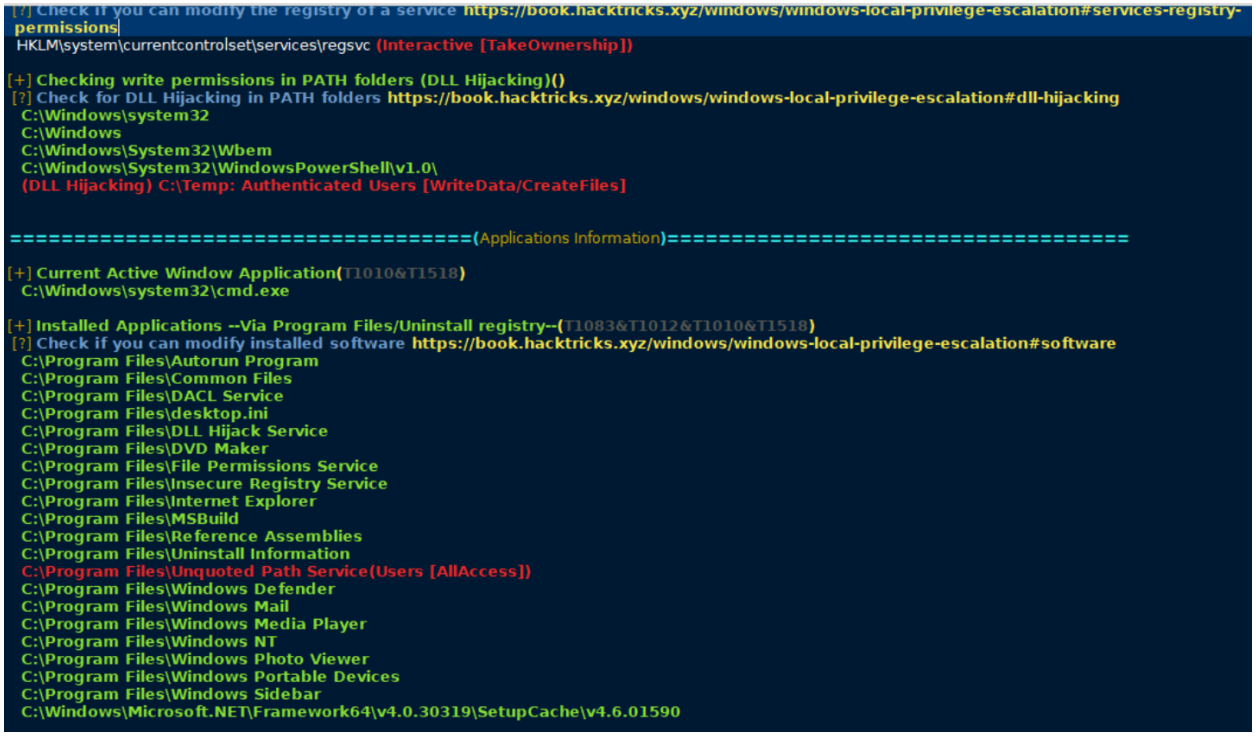
```
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> sc.exe query IPBan

SERVICE_NAME: IPBan
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE              : 4  RUNNING
                                (STOPPABLE, NOT_PAUSABLE, ACCEPTS_SHUTDOWN)
        WIN32_EXIT_CODE    : 0  (0x0)
        SERVICE_EXIT_CODE  : 0  (0x0)
        CHECKPOINT         : 0x0
        WAIT_HINT          : 0x0
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0>
```

- I installed Windows Defender Credential Guard as a PowerScript script that runs on AD and all machines at startup through group policy:
- Set the min password requirement to 8 characters: # This command sets the minimum password length to 10 for the entire domain
- Set-ADDefaultDomainPasswordPolicy -Identity team7.isucdc.com -MinPasswordLength 10 -ComplexityEnabled $true
- And I set a 30 minute account lockout after 5 failed logon attempts: Set-ADDefaultDomainPasswordPolicy -Identity team7.isucdc.com -LockoutThreshold 5 -LockoutDuration 00:30:00 -LockoutObservationWindow 00:30:00
- Ran a domain-wide policy that redirects certain websites to 0.0.0.0
    - $domains = @(
    - "github.com",
    - "gitlab.com",
    - "pastebin.com",
    - "gist.github.com",
    - "sourceforge.net",
    - "metasploit.com",
    - "exploit-db.com",
    - "packetstormsecurity.com",
    - "nmap.org",
    - "pentest-tools.com",
    - "dropbox.com",
    - "drive.google.com",
    - "mega.nz",
    - "mediafire.com",
    - "we.tl",
    - "torproject.org",
    - "protonvpn.com",
    - "psiphon.ca",
    - "ngrok.com",
    - "serveo.net",
    - "noip.com",
    - "duckdns.org",

```
    "discord.com",
    "telegram.org",
    "reddit.com",
    "twitter.com",
    "facebook.com",
    "dyn.com",
    "afraid.org"
    )

    foreach($d in $domains){
        Write-Host "Blocking $d ..." -ForegroundColor Yellow
        Add-DnsServerPrimaryZone -Name $d -ZoneFile "$d.dns" -DynamicUpdate None -ErrorAction SilentlyContinue
        Add-DnsServerResourceRecordA -ZoneName $d -IPv4Address "0.0.0.0" -Name "@" -ErrorAction SilentlyContinue
    }
    Write-Host "`nDONE — All domains are now blocked via DNS." -ForegroundColor Green
```

Security and Usability Testing

Winpeas



Nmap Scan

External scan

```
cdc@Ubuntu-External:~$ sudo nmap -sS -p- -Pn ad.team7.isucdc.com
[sudo] password for cdc:
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-20 17:10 CST
Nmap scan report for ad.team7.isucdc.com (49.49.33.10)
Host is up (0.0024s latency).
Not shown: 65532 filtered ports
PORT     STATE SERVICE
389/tcp  open  ldap
636/tcp  open  ldapssl
3389/tcp open  ms-wbt-server
MAC Address: BC:24:11:E1:54:D1 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 104.72 seconds
cdc@Ubuntu-External:~$
```

Internal scan

```
cdc@WAF:~/waf_logs$ sudo nmap -sS -Pn -p- 192.168.1.10
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-20 17:05 CST
Nmap scan report for 192.168.1.10
Host is up (0.0023s latency).
Not shown: 65516 filtered ports
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman
9389/tcp  open  adws
49666/tcp open  unknown
49667/tcp open  unknown
49679/tcp open  unknown
49680/tcp open  unknown
49705/tcp open  unknown
49746/tcp open  unknown
MAC Address: BC:24:11:48:52:7D (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 104.75 seconds
cdc@WAF:~/waf_logs$
```

Tickets Server

Domain name: Tickets.team7.isucdc.com

Public IP address: 49.49.33.20

Private IP address: 192.168.1.20

Operating system: Windows Server 2019 (1809)

Description

The Tickets server hosts the application for issuing and validating tickets for bus and train services. It represents the city's backend ticketing system and the physical ticket readers at stations and on vehicles. The application runs on port 5000 and starts automatically on boot via a scheduled task. This server also communicates with Active Directory for authentication and certificate validation. Proper functionality is essential to prevent fraudulent ticket generation and financial loss.

Vulnerability Remediation

- Removed WinRM Access via port 5895 and 5896
- Allowed RDP via 3389
- Allowed Ticket App via 5000
- Blocked NetBios on 139
- Blocked RPC on 135
- Disabled LMServer
- Disabled NetBios
- Deleted local admins scrat and backdoor
- Disabled print spooler
- Disabled Remote registry
- Enabled full audit policing: auditpol /set /category:* /success:enable /failure:enable
- Fixed windows update on the client device by running the following commands:
    - Set-Service -Name BITS -StartupType Automatic
    - Set-Service -Name wuauserv -StartupType Automatic
    - Start-Service BITS, wuauserv

    - gpupdate /force
- Downloaded windows defender by running: Install-WindowsFeature -Name Windows-Defender -IncludeAllSubFeature -IncludeManagementTools
- Disabled Guest, DefaultAccount and WDAGUtilityAccount (DID NOT DELETE)
- Deleted scrat and backdoor accounts
- Ran “New-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name "RunAsPPL" -Value 1 -PropertyType DWORD -Force” to require the LSASS process to run as protected
- Ran “Set-ItemProperty -Path "HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" -Name "CachedLogonsCount" -Value 0” to change the cached logons to 0 and prevent offline credential cracking

Security Configuration

- Set a lockout policy via CLI
    - net accounts /lockoutthreshold:5 /lockoutduration:15 /lockoutwindow:15
- Installed IPBan, running as a scheduled task, and set a 15min lockout

```
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> notepad "C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0\IPBan.config"
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> # Install the service
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> sc.exe create IPBan type= own start= auto binPath= "C:\Users\Administrator\Downloads\IPBa
ws-x64_4_0_0\DigitalRuby.IPBan.exe"
[SC] CreateService SUCCESS
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0>
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> # Start it
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> sc.exe start IPBan

SERVICE_NAME: IPBan
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE              : 2  START_PENDING
                                (NOT_STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
        WIN32_EXIT_CODE    : 0  (0x0)
        SERVICE_EXIT_CODE  : 0  (0x0)
        CHECKPOINT         : 0x0
        WAIT_HINT          : 0x7d0
        PID                : 5464
        FLAGS              :
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0>
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> # Verify it's running
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> sc.exe query IPBan

SERVICE_NAME: IPBan
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE              : 4  RUNNING
                                (STOPPABLE, NOT_PAUSABLE, ACCEPTS_SHUTDOWN)
        WIN32_EXIT_CODE    : 0  (0x0)
        SERVICE_EXIT_CODE  : 0  (0x0)
        CHECKPOINT         : 0x0
        WAIT_HINT          : 0x0
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0>
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0>
```

- Update signature on Windows defender via Update-MpSignature in Powershell
- Set Defender to use these settings:
    - PUA protection
    - Script Scanning
    - Network protection
    - MAPS Reporting
- Added a “ticket_service” user, because we do not need ticket service running as SYSTEM. This service was granted “Log on as batchjob” capability
    - Ran: icacls "C:\Users\Administrator\Desktop\tickets" /grant ticket_service:(RX) /T. This gives the tickets folder permissions

- Ran: schtasks /change /tn "Tickets Server" /ru "ticket_service" /rp "YourPasswordHere". This switched the scheduled task off SYSTEM

Security and Usability Testing

Winpeas

```
ÉÍÍÍÍÍÍÍÍÍÍ¹ Looking for Linux shells/distributions - wsl.exe, bash.exe
    C:\Windows\System32\wsl.exe

    WSL - no installed Linux distributions found.

       /---------------------------------------------------------------------------\
       |                              Do you like PEASS?                           |
       |---------------------------------------------------------------------------|
       |         Learn Cloud Hacking       :     training.hacktricks.xyz             |
       |         Follow on Twitter         :     @hacktricks_live                    |
       |         Respect on HTB            :     SirBroccoli                         |
       |---------------------------------------------------------------------------|
       |                                 Thank you!                                |
       \---------------------------------------------------------------------------/

PS C:\Users\cdc\Downloads>
```

Nmap Scan

External Scan

```
cdc@Ubuntu-External:~$ sudo nmap -sS -p- -Pn tickets.team7.isucdc.com
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-20 17:14 CST
Nmap scan report for tickets.team7.isucdc.com (49.49.33.20)
Host is up (0.0013s latency).
Not shown: 65533 filtered ports
PORT     STATE SERVICE
3389/tcp open  ms-wbt-server
5000/tcp open  upnp
MAC Address: BC:24:11:E1:54:D1 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 104.70 seconds
```

Internal Scan

```
cdc@WAF:~/waf_logs$ sudo nmap -sS -Pn -p- 192.168.1.20
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-20 17:14 CST
Nmap scan report for 192.168.1.20
Host is up (0.00028s latency).
Not shown: 65523 closed ports
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
3389/tcp  open  ms-wbt-server
5000/tcp  open  upnp
49664/tcp open  unknown
49665/tcp open  unknown
49666/tcp open  unknown
49667/tcp open  unknown
49668/tcp open  unknown
49669/tcp open  unknown
49670/tcp open  unknown
49676/tcp open  unknown
MAC Address: BC:24:11:DC:E2:CB (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 13.09 seconds
cdc@WAF:~/waf_logs$
```

Mgmt

Domain name: mgmt.team7.isucdc.com

Public IP address: 49.49.33.30

Private IP address: 192.168.1.30

Operating system: AlmaLinux (Cerulean Leopardt)

Description

The Management Backend server is the main transit management system for the city. It handles user authentication, ticket payments, and fleet and route management for all of the city's transportation. The application runs on port 5000 and is controlled via the "backend" systemd service. This server is considered mission-critical because it coordinates all transportation operations and financial transactions.

Vulnerability Remediation

- Removed all open ports except 22 and 5000
- Disabled RPCBind service
- Hardened SSH by disabling root login, setting maxauthtries to 3, and setting login grace period to 2 minutes.

-
```
[cdc@mgmt ~]$ sudo firewall-cmd --zone=mgmt --list-all
mgmt (active)
  target: DROP
  icmp-block-inversion: no
  interfaces: ens18
  sources:
  services: ssh
  ports: 5000/tcp
  protocols:
  forward: no
  masquerade: no
  forward-ports:
  source-ports:
  icmp-blocks:
  rich rules:
```
- Removed the SUID bit from fusermount to prevent privilege escalation
    - sudo chmod a-s /usr/bin/fusermount /usr/bin/fusermount3
- Moved all services from /home to /opt/backend-mgmt
- Locked down backend server file permissions to only necessities
- Put a rate limit on SSH to 30 connections/per IP/min
    - sudo firewall-cmd --add-rich-rule='rule service name="ssh" limit value="30/m" accept' --permanent
    - sudo firewall-cmd --reload
- In the systemd backend service file I added lines to block server details
    - Environment="SERVER_HEADER=False"
    - Environment="ACCESS_LOG=False"
- Deleted pcpqa user
- Locked down credential caching
    - New-ItemProperty `
    - -Path "HKLM:\Software\Microsoft\Windows NT\CurrentVersion\Winlogon" `
    - -Name "CachedLogonsCount" `
    - -PropertyType String `
    - -Value "1" `
    - -Force
- Enabled LSA protection
    - New-ItemProperty `
    - -Path "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" `
    - -Name "RunAsPPL" `
    - -PropertyType DWord `
    - -Value 1 `
    - -Force
- Reduce cached domain logons

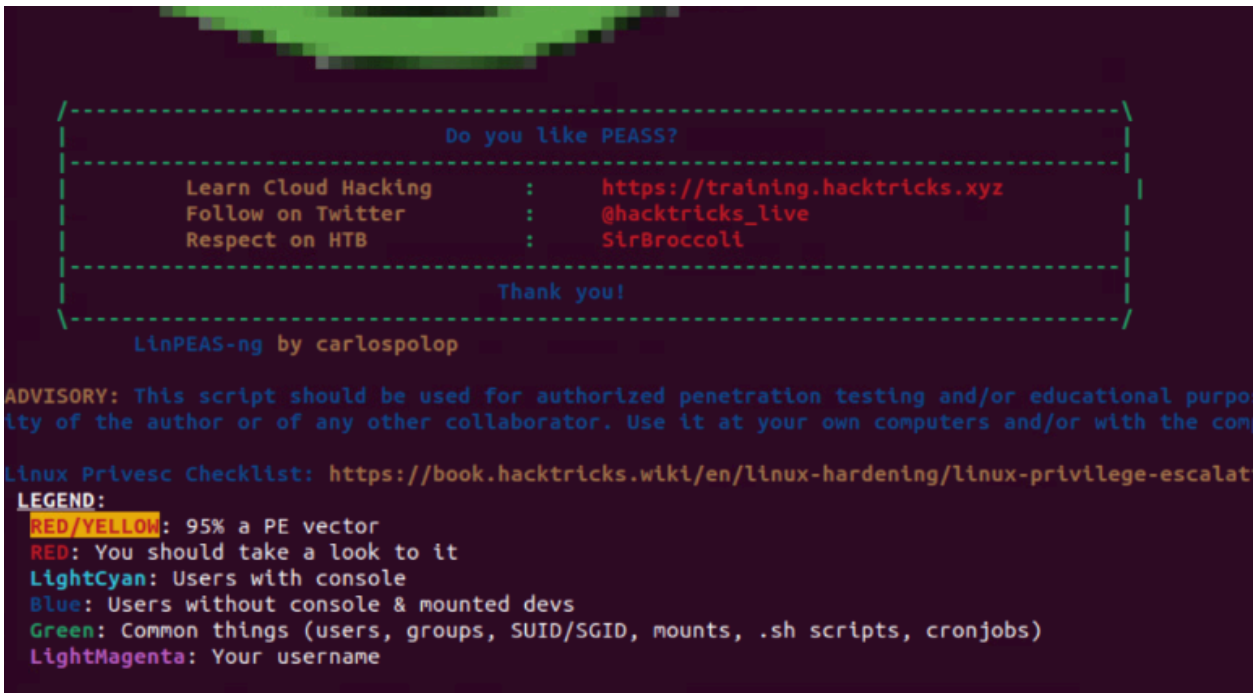
    - reg add "HKLM\Software\Microsoft\Windows NT\CurrentVersion\Winlogon" /v CachedLogonsCount /t REG_SZ /d 1 /f
- Turned on essential audit categories
    - # Log logons/logoffs
    - auditpol /set /category:"Logon/Logoff" /success:enable /failure:enable
    -
    - # Policy changes
    - auditpol /set /category:"Policy Change" /success:enable /failure:enable
    -
    - # Privilege use
    - auditpol /set /category:"Privilege Use" /success:enable /failure:enable
    -
    - # System-level changes
    - auditpol /set /category:"System" /success:enable /failure:enable
    -
    - # Object access (careful: noisy; consider enable on key objects only)
    - auditpol /set /category:"Object Access" /success:enable /failure:disable
- Restricted MariaDB to Localhost
-
```
[root@mgmt cdc]# nano /etc/my.cnf
[root@mgmt cdc]# systemctl restart mariadb
[root@mgmt cdc]# ss -tulnp | grep 3306
tcp   LISTEN 0      80         127.0.0.1:3306       0.0.0.0:*    users:(("mysqld",pid=957222,fd=26))
[root@mgmt cdc]#
```
- Changed password and cdc user priv
-
```
MariaDB [(none)]> CREATE USER 'cdc'@'%' IDENTIFIED BY 'cdc';SELECT user, host, Super_priv FROM mysql.user;
Query OK, 0 rows affected (0.002 sec)

+------+-----------+------------+
| user | host      | Super_priv |
+------+-----------+------------+
| root | localhost | Y          |
| root | alma9     | Y          |
| root | 127.0.0.1 | Y          |
| root | ::1       | Y          |
| cdc  | localhost | N          |
| cdc  | %         | N          |
+------+-----------+------------+
6 rows in set (0.001 sec)
```
- Changed ssh_config to prevent crypto protocol downgrading
    - Protocol 2
    - KexAlgorithms curve25519-sha256,curve25519-sha256@libssh.org,diffie-hellman-group14-sha256
    - Ciphers aes256-gcm@openssh.com,chacha20-poly1305@openssh.com,aes256-ctr
    - MACs hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,umac-128-etm@openssh.com
    - HostKey /etc/ssh/ssh_host_ed25519_key
    - HostKey /etc/ssh/ssh_host_ecdsa_key
    - HostKey /etc/ssh/ssh_host_rsa_key

Security Configuration

- Installed fail2ban that SSH connects to our PFsense, after 5 failed login attempts it IP bans for 15 minutes
- Upgraded to SELinux
- Put a rate limit on Port 5000 (backend) to 200 connections/per IP/min
- sudo firewall-cmd --add-rich-rule='rule port port="5000" protocol="tcp" limit value="200/m" accept' --permanent
- sudo firewall-cmd --reload
-

Security and Usability Testing

Linpeas



(we couldnt get copy and paste running on this box, so we used our internal ubuntu box)

Nmap Scan

External Scan

```
cdc@Ubuntu-External:~$ sudo nmap -sS -p- -Pn mgmt.team7.isucdc.com
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-20 17:27 CST
Nmap scan report for mgmt.team7.isucdc.com (49.49.33.30)
Host is up (0.00093s latency).
Not shown: 65533 filtered ports
PORT     STATE SERVICE
22/tcp   open  ssh
5000/tcp open  upnp
MAC Address: BC:24:11:E1:54:D1 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 104.55 seconds
```

Internal Scan

```
cdc@WAF:~/waf_logs$ sudo nmap -sS -Pn -p- 192.168.1.30
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-20 17:27 CST
Nmap scan report for 192.168.1.30
Host is up (0.00059s latency).
Not shown: 65533 filtered ports
PORT     STATE  SERVICE
22/tcp   open   ssh
5000/tcp closed upnp
MAC Address: BC:24:11:A6:8B:46 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 104.63 seconds
```

Admin

Domain name: admin.team7.isucdc.com

Public IP address: 49.49.33.40

Private IP address: 192.168.1.40

Operating system: Windows Server 2022 (21H2)

Description

The Admin server hosts the city's admin portal for viewing the status of the transportation system and managing its fleet of vehicles. Transit administrators can log in to monitor buses and trains and make fleet management decisions. This system is restricted to authorized Transit Admin users and is essential for operational oversight of the transit infrastructure.

Vulnerability Remediation

- Fixed windows update on the client device by running the following commands:
    - Set-Service -Name BITS -StartupType Automatic
    - Set-Service -Name wuauserv -StartupType Automatic
    - Start-Service BITS, wuauserv
    - gpupdate /force
- Edited scheduled task for admin ui to get it bound to 80 and to survive a reboot
- Stopped the task from shutting down after 3 days in Scheduled Tasks
- The guest user was in the administrator group
    - Remove-LocalGroupMember -Group "Administrators" -Member "Guest"
- Reduced cached logon credentials
    - # Set to 1 cached credential
    - reg add "HKLM\Software\Microsoft\Windows NT\CurrentVersion\Winlogon" /v CachedLogonsCount /t REG_SZ /d 1 /f
- Enabled LSA protection
    - reg add "HKLM\SYSTEM\CurrentControlSet\Control\Lsa" /v RunAsPPL /t REG_DWORD /d 1 /f
    - reg add "HKLM\SYSTEM\CurrentControlSet\Control\Lsa" /v RunAsPPLBoot /t REG_DWORD /d 1 /f
- Turned on transcription

    - reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows\PowerShell\Transcription" /v EnableTranscripting /t REG_DWORD /d 1 /f
    - reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows\PowerShell\Transcription" /v OutputDirectory /t REG_SZ /d "C:\PSLogs" /f
    - mkdir C:\PSLogs
    - icacls C:\PSLogs /inheritance:r /grant "Administrators:(OI)(CI)F" /grant "SYSTEM:(OI)(CI)F"
- Removed a debug pin
    - # System env var
    - [Environment]::SetEnvironmentVariable("WERKZEUG_DEBUG_PIN", $null, "Machine")
    -
    - # Current user (Administrator)
    - [Environment]::SetEnvironmentVariable("WERKZEUG_DEBUG_PIN", $null, "User")
- Enabled network level auth
    - reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server\WinStations\RDP-Tcp" /v UserAuthentication /t REG_DWORD /d 1 /f
- Disabled alwaysinstallelevated for low-priv users found by Winpeas
    - # Make sure Installer policy path exists under HKLM
    - reg add "HKLM\Software\Policies\Microsoft\Windows\Installer" /f
    -
    - # Disable AlwaysInstallElevated under HKLM
    - reg add "HKLM\Software\Policies\Microsoft\Windows\Installer" /v AlwaysInstallElevated /t REG_DWORD /d 0 /f
    -
    - # Make sure Installer policy path exists under HKCU
    - reg add "HKCU\Software\Policies\Microsoft\Windows\Installer" /f
    -
    - # Disable AlwaysInstallElevated under HKCU
    - reg add "HKCU\Software\Policies\Microsoft\Windows\Installer" /v AlwaysInstallElevated /t REG_DWORD /d 0 /f
- Enabled network protection
    - Set-MpPreference -EnableNetworkProtection Enabled
- Enabled cloud protection and MAPS reporting
    - Set-MpPreference -MAPSReporting Advanced
    - Set-MpPreference -SubmitSamplesConsent SendSafeSamples
- Enable controlled folder access
    - Set-MpPreference -EnableControlledFolderAccess Enabled
    - Add-MpPreference -ControlledFolderAccessAllowedApplications "C:\Users\Administrator\Desktop\icdc26-admin-ui\AdminUI.exe"
- Enabled account lockout protection

    - net accounts /lockoutthreshold:5
    - net accounts /lockoutduration:15
    - net accounts /lockoutwindow:15
- Set firewall policy to block incoming except necessary
    - Set-NetFirewallProfile -Profile Domain,Public,Private -DefaultInboundAction Block
- Blocked SMB, WinRM and RPC
    - Get-NetFirewallRule -DisplayGroup "File and Printer Sharing" | Disable-NetFirewallRule
    - Get-NetFirewallRule -DisplayGroup "Remote Service Management" | Disable-NetFirewallRule
- Disabled Powershell v2
    - Disable-WindowsOptionalFeature -Online -FeatureName MicrosoftWindowsPowerShellV2Root -NoRestart
- Block executable content from web/mail
    - Set-MpPreference -AttackSurfaceReductionRules_Ids D4F940AB-401B-4EFC-AADC-AD5F3C50688A `
    - -AttackSurfaceReductionRules_Actions 1
- Block credential stuffing from LSASS
    - Set-MpPreference -AttackSurfaceReductionRules_Ids 9E6C4E1F-7B2C-4A7D-88C6-0C6CDBF8F366 `
    - -AttackSurfaceReductionRules_Actions 1

Security Configuration

- Turned on script block and module logging
    - # Enable script block logging
    - reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging" /v EnableScriptBlockLogging /t REG_DWORD /d 1 /f
    -
    - # Enable module logging for all modules
    - reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ModuleLogging" /v EnableModuleLogging /t REG_DWORD /d 1 /f
    - reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ModuleLogging" /v ModuleNames /t REG_MULTI_SZ /d * /f
- Installed IPBan, running as a scheduled task, and set a 15min lockout

```
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> sc.exe create IPBan type= own start= auto binPath= "C:\Use
s\Administrator\Downloads\IPBan-Windows-x64_4_0_0\DigitalRuby.IPBan.exe"
[SC] CreateService SUCCESS
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0>
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> # Start it
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> sc.exe start IPBan

SERVICE_NAME: IPBan
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE              : 2  START_PENDING
                                (NOT_STOPPABLE, NOT_PAUSABLE, IGNORES_SHUTDOWN)
        WIN32_EXIT_CODE    : 0  (0x0)
        SERVICE_EXIT_CODE  : 0  (0x0)
        CHECKPOINT         : 0x0
        WAIT_HINT          : 0x7d0
        PID                : 5192
        FLAGS              :
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0>
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> # Verify it's running
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0> sc.exe query IPBan

SERVICE_NAME: IPBan
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE              : 2  START_PENDING
                                (STOPPABLE, NOT_PAUSABLE, ACCEPTS_SHUTDOWN)
        WIN32_EXIT_CODE    : 0  (0x0)
        SERVICE_EXIT_CODE  : 0  (0x0)
        CHECKPOINT         : 0x0
        WAIT_HINT          : 0x0
PS C:\Users\Administrator\Downloads\IPBan-Windows-x64_4_0_0>
```

- Enabled windows defender, updated signatures, enabled all real-time protections and blocking

Security and Usability Testing

Winpeas

```
ADVISORY: winpeas should be used for authorized penetration testing and/or educational p
at your own networks and/or with the network owner's permission.

 WinPEASng by @carlospolopm, makikvues(makikvues2[at]gmail[dot]com)

      /---------------------------------------------------------------------\
      |                             Do you like PEASS?                      |
      |-----------------------------------------------------------------------|
      |         Become a Patreon     :     https://www.patreon.com/peass      |
      |         Follow on Twitter    :     @carlospolopm                      |
      |         Respect on HTB       :     SirBroccoli & makikvues            |
      |-----------------------------------------------------------------------|
      |                                Thank you!                             |
      \---------------------------------------------------------------------/

 [+] Legend:
        Red                Indicates a special privilege over an object or something is
        Green              Indicates that some protection is enabled or something is we
        Cyan               Indicates active users
        Blue               Indicates disabled users
        LightYellow        Indicates links
```

Nmap Scans

External Scan

```
cdc@Ubuntu-External:~$ sudo nmap -sS -p- -Pn admin.team7.isucdc.com
[sudo] password for cdc:
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-20 17:42 CST
Nmap scan report for admin.team7.isucdc.com (49.49.33.40)
Host is up (0.0014s latency).
Not shown: 65533 filtered ports
PORT     STATE SERVICE
80/tcp   open  http
3389/tcp open  ms-wbt-server
MAC Address: BC:24:11:E1:54:D1 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 104.59 seconds
```

Internal Scan

```
cdc@WAF:~/waf_logs$ sudo nmap -sS -Pn -p- 192.168.1.40
[sudo] password for cdc:
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-20 17:42 CST
Nmap scan report for 192.168.1.40
Host is up (0.00087s latency).
Not shown: 65533 filtered ports
PORT     STATE SERVICE
80/tcp   open  http
3389/tcp open  ms-wbt-server
MAC Address: BC:24:11:95:96:B8 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 104.35 seconds
```

WWW

Domain name: www.team7.isucdc.com

Public IP address: 49.49.33.50

Private IP address: 192.168.1.50

Operating system: AlmaLinux (Moss Jungle Cat)

Description

The WWW server hosts the city's public-facing website. Citizens can register, view bus and train routes, manage their accounts, purchase tickets, and scan tickets from this website. The application runs on port 80 and is controlled via the "frontend" systemd service. This server is publicly accessible and must remain highly available while maintaining strong security controls to protect user data and financial transactions.

Vulnerability Remediation

- Deleted 0anacron file
- Configured DNS settings to set DNS server to our AD (49.49.33.10)
- Set SSH settings to match spec: sudo sshd -T | egrep -i 'passwordauthentication|kbdinteractiveauthentication|usepam|pubkeyauthentication|permitrootlogin'
- Enabled password auth via a drop in: sudo tee /etc/ssh/sshd_config.d/50-cdc-password.conf >/dev/null <<'EOF'
    - PasswordAuthentication yes
    - KbdInteractiveAuthentication no
    - UsePAM yes
    - PubkeyAuthentication yes
    - PermitRootLogin no
    - EOF
- Added cdc user to wheel: sudo usermod -aG wheel cdc
- Changed password requirements in: sudo nano /etc/security/pwquality.conf
    - minlen = 14
    - dcredit = -1

    - ucredit = -1
    - lcredit = -1
    - ocredit = -1
- Deleted the taco account: sudo userdel -r taco
- Deleted 01-permitrootlogin.conf file to stop ROOT via SSH
- Disabled performance metric stack via: sudo systemctl disable --now pmcd pmie pmie_farm pmlogger pmlogger_farm
- Disabled ATD and irqbalance service
- Edited file permissions for hardening:
    - sudo chmod 600 /etc/shadow
    - sudo chmod 644 /etc/passwd
    - sudo chmod 600 /etc/ssh/sshd_config
- Setup PAM faillock with a 10-min temp autoban for multiple failed logins
    - sudo authselect current
    - sudo authselect enable-feature with-faillock
    - sudo authselect apply-changes
        - With these policies:
        - sudo tee /etc/security/faillock.conf >/dev/null <<'EOF'
        - deny = 5
        - unlock_time = 600
        - fail_interval = 600
        - EOF
- Disabled these unnecessary services:
    - sudo systemctl disable --now bluetooth
    - sudo systemctl disable --now iscsid
    - sudo systemctl disable --now iscsi
    - sudo systemctl disable --now iscsi-starter
    - sudo systemctl disable --now oddjob
    - sudo systemctl disable --now kdump
    - sudo systemctl disable --now rpcbind
    - sudo systemctl disable --now multipathd
    - sudo systemctl disable --now smartd
    - sudo systemctl disable --now upower
    - sudo systemctl disable --now vgauthd
- Because I am running the frontend as cdc and NOT root, I had to bypass the “Can’t bind to 80 without root” issue from SELinux. I edited the frontend and added these to
    - [Service]
    - AmbientCapabilities=CAP_NET_BIND_SERVICE
    - CapabilityBoundingSet=CAP_NET_BIND_SERVICE
    - NoNewPrivileges=true
- Disabled suspicious “Ticket_mon” service
- Uninstall service
    - httpd|pcp|pmda|nmap|tcpdump|vsftpd|tigervnc|gcc-toolset
    - And turned off chronyd on port 323, has a 2025 vulnerability.

- PLAYTUPUS
-
```
[root@www mnt]# echo $LD_PRELOAD
/usr/lib64/nsabackdoor.so
[root@www mnt]#
```
- Neutralize from Current shell
    - unset LD_PRELOAD
    - export LD_PRELOAD=
- Remove with persistence
    - vi /etc/profile.d/setup.sh
    - Deleted

        export LD_PRELOAD=/usr/lib64/nsabackdoor.so
- Making it so that the cdc user required password to run sudo.
- Added a rate limit of 30/min for ssh and 50/min with http with the Host firewall
-

Security Configuration

- Installing fail2Ban and configuring
    - sudo dnf update -y
    - sudo dnf install epel-release -y
    - sudo dnf install fail2ban fail2ban-firewalld -y
    - Configured it to ban IP for 15 minutes after 5 failed attempts
- To get the website working after switching to enforcing, I did this:
    - sudo mkdir -p /opt/frontend
    - sudo mv /home/cdc/icdc2026frontend-main /opt/frontend/
    - sudo chown -R root:root /opt/frontend
    - sudo restorecon -Rv /opt/frontend
    - After this, I needed to edit the frontend service files to run python then flask, because flask still was in /home
- Edited /etc/selinux/config
    - Set SELinux to “enforcing” from “disabled”
- Edited /etc/default/grub
    - Removed “SElinux=0”
- Forced grub to take SELinux=enforcing. Relabeled

Security and Usability Testing

Linpeas Scan

```
/---------------------------------------------------------------------------\
|                             Do you like PEASS?                            |
|---------------------------------------------------------------------------|
|         Learn Cloud Hacking       :     https://training.hacktricks.xyz   |
|         Follow on Twitter         :     @hacktricks_live                  |
|         Respect on HTB            :     SirBroccoli                       |
|---------------------------------------------------------------------------|
|                                 Thank you!                                |
\---------------------------------------------------------------------------/
      LinPEAS-ng by carlospolop

ADVISORY: This script should be used for authorized penetration testing and/or educational purposes only.
lity of the author or of any other collaborator. Use it at your own computers and/or with the computer ow

Linux Privesc Checklist: https://book.hacktricks.wiki/en/linux-hardening/linux-privilege-escalation-check
 LEGEND:
  RED/YELLOW: 95% a PE vector
  RED: You should take a look to it
  LightCyan: Users with console
  Blue: Users without console & mounted devs
  Green: Common things (users, groups, SUID/SGID, mounts, .sh scripts, cronjobs)
  LightMagenta: Your username

 Starting LinPEAS. Caching Writable Folders...

                              Basic information
```

Nmap Scan

External Scan

```
cdc@Ubuntu-External:~$ sudo nmap -sS -p- -Pn www.team7.isucdc.com
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-20 17:46 CST
Nmap scan report for www.team7.isucdc.com (49.49.33.50)
Host is up (0.00091s latency).
Not shown: 65533 filtered ports
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: BC:24:11:E1:54:D1 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 104.47 seconds
```

Internal Scan

```
cdc@WAF:~/waf_logs$ sudo nmap -sS -Pn -p- 192.168.1.50
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-20 17:46 CST
Nmap scan report for 192.168.1.50
Host is up (0.00057s latency).
Not shown: 65533 filtered ports
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: BC:24:11:25:7D:A6 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 104.49 seconds
```

Network Firewall

Public IP address: 49.49.33.150

Private IP address: 192.168.1.1

LAN Network: 192.168.1.0/24

Operating system: FreeBSD 13.2

Description

This server is running pfSense-CE-2.7.2 and serves as our network firewall. Every competition machine is behind this firewall and utilizes port forwarding as described earlier.

Security Configuration

We configured Fail2Ban to connect to the network firewall so that each machine when something fails It'll block that ip for 15 mins network wide.

SIEM

Private IP address: 192.168.1.45

Operating system: Ubuntu Desktop 22.04.5 LTS (Jammy Jellyfish)

Description

This server is running Wazuh 4.10 and functions as our SIEM/XDR server. Each competition machine has a Wazuh agent installed that forwards various logs and system information to this server for analysis.

Web Application Firewall

Private IP address: 192.168.1.35

Operating system: Ubuntu Desktop 22.04.5 LTS (Jammy Jellyfish)

Description

This server is running Mod Security and functions as a web application firewall. This server intercepts requests to the web server and analyzes them for common web attacks. The web server was configured to redirect users to this server so that all web traffic to the web server must be analyzed by the web application firewall.

Security Configuration

We configured Fail2Ban to connect to the modsecurity waf so that when a rule is triggered then in addition to our loging users are blocked through here.